Sicurezza dei Sistemi Informativi

Appello d'Esame del 03 Aprile 2023

Anno Accademico 2022-2023

Politecnico di Torino — Docente: Prof. Cataldo Basile

2023-04-03

1 Testo Ufficiale dell'Esame

Domanda 1: Algoritmo 3DES

Cosa è 3DES?

a. Un algoritmo di crittografia asimmetrica

b. Un algoritmo di crittografia simmetrica a blocchi con chiave da 160 bit e blocco da 64

c. Un algoritmo di crittografia simmetrica a blocchi con chiave da 56 bit e blocco da 64

d. Un algoritmo di crittografia simmetrica di tipo stream

e. Nessuna delle precedenti

Domanda 2: Offuscamento del Software

Cosa è l'offuscamento del software?

a. Una tecnica per rendere il codice binario illeggibile per i disassemblatori e quindi più difficilmente attaccabile

b. Nessuna delle precedenti

c. Una tecnica che permette di rallentare gli attaccanti perché rende il codice più lungo e complesso quindi più difficile sia da comprendere che da modificare

d. Una famiglia di tecniche che permettono di rallentare gli attaccanti perché rendono il codice più complesso quindi più difficile da modificare

e. Una famiglia di tecniche che permettono di rallentare gli attaccanti perché rendono la fruizione e comprensione del software più difficile

Domanda 3: Ruolo e Funzioni del SOC

Cosa è un Security Operations Center (SOC)?

a. È un sistema di gestione degli attacchi che usa eventi e metodi attivi.

b. È un sistema di monitoring che permette l'interazione automatica con sistemi di difesa, es. i firewall mediante la gestione degli eventi e delle operazioni.

c. Nessuna delle precedenti.

d. È una soluzione che serve a garantire la sicurezza delle operazioni aziendali.

e. È un dipartimento/unità organizzativa che si occupa di identificare, monitorare, gestire e mitigare le minacce oltre a rispondere agli incidenti di sicurezza.

Domanda 4: Selezione di Controlli e Architetture di Sicurezza

Indicare e motivare brevemente quale controllo, tecnologia o architettura di sicurezza utilizzereste per implementare le seguenti policy di sicurezza:

1. Scoprire in tempo reale o nel più breve tempo possibile se è in corso un attacco nella mia rete locale;
2. Autenticare gli utenti aziendali prima di permettere loro di accedere ad Internet;
3. Evitare che alcuni host, descritti mediante una blacklist di URL, riescano a raggiungere un server aziendale;
4. Permettere agli utenti di un'azienda di usare da casa dei servizi aziendali non accessibili all'esterno della rete privata aziendale.

Domanda 5: Ransomware: Funzionamento, Impatto e Mitigazioni

Spiegare cosa è e come funziona un ransomware. Descrivere l'impatto sulle vittime e i vantaggi economici per gli attaccanti. Illustrare due contromisure efficaci: una preventiva per impedire l'infezione iniziale e una reattiva/di resilienza per mitigare al massimo le conseguenze dell'attacco senza pagare il riscatto.

Domanda 6: IPsec v2 Authentication Header (AH)

Indicare quali proprietà di sicurezza possono essere applicate al traffico usando IPsec (v2) AH in funzione dei modi di utilizzo (Transport Mode vs Tunnel Mode). Per ognuna delle proprietà indicate, riportare se sono obbligatorie o opzionali e a quale parte del pacchetto IP originale si applicano (ATTENZIONE: con riferimento esplicito alle parti del pacchetto originale).

Domanda 7: Confronto tra MAC e Firma Digitale

Spiegare cosa sono e quali proprietà garantiscono il Message Authentication Code (MAC) e la Firma Digitale. Spiegare quali operazioni matematiche devono essere svolte e quali segreti (chiavi simmetriche vs chiavi private) devono essere utilizzati per calcolarli e verificarli. Discutere i vantaggi e svantaggi relativi in termini di efficienza computazionale e proprietà di non ripudio. Indicare quale tecnica sceglierete per autenticare i dati inviati da un server pubblico verso milioni di client sconosciuti.

Domanda 8: Obiettivi e Principi del GDPR

Spiegare cosa è il GDPR, quale è il suo obiettivo istituzionale e illustrare nel dettaglio almeno 4 dei principi fondamentali che disciplinano i trattamenti e i servizi che utilizzano dati personali.

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: Algoritmo 3DES

Analisi Puntuale delle Opzioni:

- **a. FALSA**: 3DES (Triple Data Encryption Standard) è un algoritmo di crittografia simmetrica a blocchi, non un algoritmo asimmetrico a chiave pubblica.
- **b. FALSA**: La dimensione del blocco in 3DES è ereditata dal DES originale ed è pari a **64 bit** (8 byte), ma la lunghezza della chiave non è mai di 160 bit. A seconda dell'opzione di keying, la lunghezza complessiva è di 168 bit (3 chiavi indipendenti da 56 bit: $3 \times 56 = 168$ bit) o di 112 bit (2 chiavi indipendenti: $2 \times 56 = 112$ bit).
- **c. FALSA**: Una chiave da 56 bit corrisponde al DES singolo originale, non al Triplo DES (3DES), che applica tre iterazioni consecutive ($C = E_{K3}(D_{K2}(E_{K1}(P)))$).
- **d. FALSA**: 3DES è un cifrario a blocchi (*block cipher*) basato sulla rete di Feistel, non un cifrario di flusso (*stream cipher*).
- **e. VERA**: Poiché nessuna delle opzioni (a), (b), (c), (d) riporta le specifiche tecniche corrette (blocco da 64 bit e chiave da 168 o 112 bit), la risposta corretta è rigorosamente ed univocamente la **(e)**.

Soluzione Domanda 2: Offuscamento del Software

Analisi Puntuale delle Opzioni:

- **a. FALSA**: I disassemblatori operano decodificando i byte binari in istruzioni assembly in base all'ISA del processore; l'offuscamento non impedisce la decodifica delle istruzioni macchina, ma distrugge le astrazioni di alto livello rendendo incomprensibile la logica del programma.
- **b. FALSA**: L'opzione (e) definisce correttamente e compiutamente il concetto di offuscamento.
- **c. FALSA**: L'offuscamento non è una singola tecnica isolata, ma un insieme strutturato di metodologie; inoltre l'aumento della lunghezza del codice è solo un eventuale effetto collaterale di alcune trasformazioni (es. inlining o inserimento di dead code), non il principio cardine (che comprende invece predicati opachi, trasformazioni di controllo di flusso, ecc.).
- **d. FALSA**: Definizione incompleta e riduttiva: l'offuscamento non mira unicamente a ostacolare la modifica (*tampering*), ma primariamente a contrastare la comprensione semantica del funzionamento (*reverse engineering*) da parte dell'analista umano.
- **e. VERA**: L'offuscamento del software è formalmente una **famiglia di tecniche** di trasformazione del codice che, preservando la semantica funzionale del programma originario, massimizza la complessità cognitiva e computazionale dell'analisi nel modello MATE, rallentando considerevolmente gli avversari nella fruizione e comprensione della logica applicativa.

Soluzione Domanda 3: Ruolo e Funzioni del SOC

Analisi Puntuale delle Opzioni:

- **a. FALSA**: Il SOC non è un software o un sistema isolato di gestione, ma una vera e propria struttura organizzativa umana e metodologica.
- **b. FALSA**: Riduce erroneamente il SOC a un mero strumento di monitoraggio o ad una feature di integrazione automatica con i firewall.
- **c. FALSA**: L'affermazione (e) fornisce la definizione formale corretta e completa.
- **d. FALSA**: Definizione eccessivamente vaga, generica e priva dei requisiti tecnici specialistici dell'Information Security.
- **e. VERA**: Il **Security Operations Center (SOC)** è formalmente un dipartimento / unità organizzativa aziendale centralizzata composta da persone qualificate (analisti L1/L2/L3, incident responder, digital forensics specialist, threat hunter), processi operativi e tecnologie avanzate (SIEM, SOAR, EDR, NDR) incaricata di identificare, monitorare continuativamente, gestire e mitigare gli incidenti informatici garantendo la resilienza aziendale.

Soluzione Domanda 4: Selezione di Controlli di Sicurezza

1. **Scoprire in tempo reale attacchi in LAN**: Si adotta un **Network Intrusion Detection/Prevention System (NIDS/NIPS)** (es. Snort, Suricata, Zeek) collegato a una porta SPAN/mirror dello switch o con inline tap, integrato con un **SIEM/EDR** per la correlazione di eventi su endpoint.
2. **Autenticare utenti aziendali prima dell'accesso ad Internet**: Si utilizza un **Captive Portal** con autenticazione 802.1X/RADIUS o un **Proxy di Autenticazione (Forward Proxy)** integrato con directory aziendale (Active Directory / LDAP / Kerberos / SAML).
3. **Bloccare host descritti da una blacklist di URL**: Si implementa un **Web Application Firewall (WAF) / Reverse Proxy** di livello applicativo (L7) posto a protezione del server, in grado di ispezionare l'URI HTTP della richiesta e confrontarla con la blacklist prima dell'inoltro.
4. **Accesso remoto sicuro da casa a servizi interni**: Si implementa una **Virtual Private Network (VPN) Remote Access** (IPsec o TLS/OpenVPN) con autenticazione a più fattori (MFA) obbligatoria e posture check del dispositivo client.

Soluzione Domanda 5: Ransomware

Funzionamento e Impatto: Il ransomware è un malware che cifra i file dell'utente (documenti, database, immagini) impiegando uno schema ibrido: genera chiavi simmetriche casuali (es. AES-256) per cifrare velocemente i file locali, e poi cifra tali chiavi con la chiave pubblica RSA/ECC dell'attaccante. Elimina inoltre i punti di ripristino (*Volume Shadow Copies*). Negli attacchi moderni (*Double Extortion*), gli attaccanti esfiltrano preventivamente i dati sensibili prima di cifrarli, minacciando di pubblicarli se il riscatto (in criptovaluta) non viene pagato.

Due Contromisure Chiave:

- **Preventiva**: Formazione anti-phishing, filtri email avanzati con sandboxing degli

allegati, patch management celere delle vulnerabilità esposte, e disabilitazione di protocolli rischiosi come RDP su Internet pubblico.

- **Reattiva/Resilienza**: Strategia di **Backup 3-2-1 Immutabile e Offline** (3 copie dei dati, su 2 supporti differenti, di cui almeno 1 conservata offsite/offline o su storage WORM — Write Once Read Many non modificabile dal malware).

Soluzione Domanda 6: IPsec v2 AH — Proprietà e Copertura Pacchetto

Proprietà Garantite da AH:

1. **Integrità senza connessione**: Obbligatoria.
2. **Autenticazione dell'origine dei dati**: Obbligatoria.
3. **Protezione anti-replay**: Opzionale ma standard (gestita mediante Sequence Number a 32/64 bit).
4. **Confidenzialità**: **Non fornita** in alcun caso da AH.

Copertura rispetto al Pacchetto IP Originale:

- **In Transport Mode**: L'AH viene inserito immediatamente tra l'header IP originale e il payload originale (es. TCP). *Copertura*: Il controllo di integrità (ICV) copre l'intero payload originale e tutti i campi immutabili dell'header IP originale (sono esclusi i campi mutabili durante il routing: TTL, Type of Service, Checksum, Flags di frammentazione).
- **In Tunnel Mode**: Viene creato un nuovo header IP esterno e l'intero pacchetto IP originale (inclusi tutti i suoi campi header) diventa payload del nuovo pacchetto. *Copertura*: L'ICV copre l'intero pacchetto IP originale nella sua totalità, oltre ai campi immutabili del nuovo header IP esterno.

Soluzione Domanda 7: MAC vs Firma Digitale

Caratteristica	Message Authentication Code (MAC)	Firma Digitale
Crittografia	Simmetrica (chiave condivisa K).	Asimmetrica (chiave privata K_{pr} per firmare, pubblica K_{pub} per verificare).
Calcolo	$Tag = \text{HMAC}_K(M)$ o CBC-MAC/GMAC.	$S = \text{Sign}_{K_{pr}}(H(M))$ (es. RSA-PSS, ECDSA, Ed25519).
Verifica	Il destinatario usa la stessa chiave K per ricalcolare il tag e confrontarlo.	Chiunque possieda la chiave pubblica K_{pub} verifica che $\text{Verify}(K_{pub}, M, S) == \text{True}$.
Non-Ripudio	**Assente**: poiché entrambe le parti condividono K, il destinatario avrebbe potuto creare il tag autonomamente.	**Garantito**: solo il titolare della chiave privata K_{pr} può generare una firma valida.
Efficienza	Estremamente veloce e a basso costo computazionale.	Più lenta (richiede operazioni su campi algebrici/curve ellittiche).

Scelta per Server Pubblico verso Milioni di Client Sconosciuti: Si deve utilizzare la **Firma Digitale** (con certificati X.509 emessi da una CA pubblica di fiducia). Con un

MAC simmetrico, il server dovrebbe o condividere un'unica chiave simmetrica con tutti (distruggendo qualsiasi forma di autenticazione e sicurezza) o negoziare miliardi di chiavi segrete individuali a priori, cosa impraticabile.

Soluzione Domanda 8: GDPR — Obiettivi e 4 Principi Fondamentali

Obiettivo: Tutela dei diritti fondamentali delle persone fisiche con particolare riguardo alla protezione dei dati personali e alla libertà di circolazione dei dati all'interno dello Spazio Economico Europeo.
4 Principi Fondamentali (Art. 5 GDPR):

1. **Liceità, Correttezza e Trasparenza**: Il trattamento deve avere una base giuridica valida (consenso, obbligo contrattuale, obbligo di legge) ed essere trasparente per l'interessato.
2. **Limitazione della Finalità**: I dati devono essere raccolti solo per scopi determinati, espliciti e legittimi, vietando trattamenti secondari incompatibili.
3. **Minimizzazione dei Dati**: Devono essere raccolti solo i dati indispensabili per l'erogazione della prestazione richiesta.
4. **Limitazione della Conservazione**: I dati non devono essere conservati più a lungo di quanto strettamente necessario per le finalità dichiarate.

Alternative Implementation Note: Strutture Rust per Firme Digitali e Caching di Certificati

In applicazioni ad alto carico di rete (come un gateway di verifica firme digitali in Rust):

- Si utilizza la libreria standard `ring` o `ed25519-dalek` integrata con un pool di worker thread tramite `crossbeam::channel` per il calcolo parallelo delle firme senza bloccare il thread di rete.
- `std::sync::Arc<rustls::RootCertStore>`: Il repository dei certificati CA fidati viene condiviso in sola lettura tra tutti i thread senza alcuna contesa di memoria.